NovaCart Support Playbook: Account & Login Security

Category: Account & Login | **Document ID:** SOP-OPS-AL-04 | **Version:** 2026.4 | **Scope:** Tier 1-3 Support

Section 1: Identity Verification, PII Handling & Access Governance

1.1 Compliance Scope: This document governs the identification, authentication, and security management of customer accounts across NovaCart, complying with global privacy frameworks (GDPR, CCPA) and payment card security guidelines.

1.2 Strict Identity Verification Standards

- **Low-Risk Inquiries (Order tracking, general FAQ):** Verify registered customer full name and order shipping address.
- **Medium-Risk Inquiries (Address change, order cancellation):** Verify registered email address, phone number, and last 4 digits of payment card used.
- **High-Risk Inquiries (Password reset, email change, 2FA bypass):** Mandatory 2-factor OTP verification plus verification of two recent purchase order IDs with exact billing names.

1.3 Prohibited Customer Information (Strict Redaction)

Data Type	Visibility Status	CRM Storage Rule	Agent Protocol
Full Credit Card Number	Masked (shows last 4 only)	PCI-DSS Tokenized; raw PAN never stored.	Never request full card number or CVV under any circumstance.
Account Password	Completely Hidden	One-way bcrypt hashed with cryptographic salt.	Agents cannot view or set plain text passwords.
Government ID / Passport	Encrypted Document Vault	Restricted access to Tier-3 Trust & Safety team.	Must be redacted from tickets post-verification.
Saved Addresses	Partially Masked	Decrypted only upon authorized authenticated session.	Confirm with customer by having them recite details.

Section 2: Login Troubleshooting, MFA Resets & Lockouts

2.1 Common Access Failure Modes: Account access barriers usually stem from credential stuffing security locks, lost Multi-Factor Authentication (MFA) devices, or expired social sign-in OAuth tokens.

2.2 Systematic Access Recovery Workflows

- **Automated Password Reset Delivery Failure:** Confirm customer is checking spam/junk folders. Verify email domain is not blacklisting NovaCart relay IPs. CSR can trigger a cryptographically signed 15-minute emergency reset link via alternative SMS rail.
- **Rate-Limit Lockouts (Brute Force Protection):** System enforces a 30-minute cooling off period following 5 consecutive failed login attempts. Tier-1 agents may manually release IP/Username lockout only after successful phone OTP challenge verification.
- **Lost MFA / Authenticator Device:** Initiate **MFA Recovery Journey** requiring customer to submit secondary verification (verified phone SMS code + photo ID selfie match).

2.3 MFA Reset Authorization Hierarchy

Customer Scenario	Required Verification	Approval Authority	Processing SLA
Has access to registered phone	SMS OTP + verification of billing ZIP.	CSR Tier-1	Immediate (< 5 minutes)
Lost phone & authenticator app	Email OTP + Photo ID match via portal.	Security Operations Tier-2	2 to 4 Business Hours
Lost all recovery channels	Government ID + Video notary call.	Trust & Safety Manager	24 Business Hours
Suspected compromised account	Complete credential freeze and reset.	Senior Fraud Analyst	Immediate freeze; 12h review

Section 3: Account Takeover (ATO) Defense & Fraud Investigations

3.1 Account Takeover (ATO) Indicators: ATO occurs when unauthorized third parties acquire account access via phishing or credential leaks. CSRs must immediately freeze accounts when ATO signals trigger.

3.2 Critical ATO Behavioral Signatures

- Sudden change of registered email address followed immediately by high-value electronics purchase.
- Addition of new shipping address in a different geographical region followed by rapid order placement using saved payment cards.
- Simultaneous failed password attempts followed by successful login from an anonymizing Tor exit node or foreign IP range.

3.3 ATO Incident Remediation Protocol

Step	Action Item	System Execution	Customer Communication
1. Immediate Freeze	Lock account access.	Click `KILL_SESSION_AND_LOCK` in CRM.	Send system alert to original phone number.
2. Order Intercept	Cancel unauthorized pending orders.	Trigger `LOGISTICS_INTERCEPT_RECALL`.	Assure customer saved card will not be settled.
3. Payment Scrub	Purge saved card tokens.	Flush vault tokens in Stripe integration.	Advise user to notify card-issuing bank.
4. Account Reclaim	Verify rightful owner.	Perform live verification; restore original email.	Issue password reset to confirmed secure email.

Section 4: Profile Merges, Data Privacy & GDPR/CCPA Compliance

4.1 Account Lifecycle Management: Standardizing processes for customer profile updates, duplicate account deduplication, and statutory data subject access requests.

4.2 Duplicate Account Merging Rules

- Accounts can only be merged if both accounts share identical verified billing names and verified government ID numbers.
- Wallet balances, NovaCart reward points, and order history from Account B are merged into primary Account A.
- Merged accounts cannot be unlinked once ledger consolidation script completes.

4.3 Right to Erasure / Account Deletion (GDPR Art. 17 / CCPA)

Prerequisite Check	Policy Requirement	Blocker Condition	Resolution Action
Active Orders Pending	All shipments must be in `DELIVERED` status.	Order currently in transit.	Wait until package is delivered.
Open Returns / Refunds	All reverse shipments & refunds closed.	Active refund processing.	Hold deletion until ledger settlement.
Outstanding Debt / Pay-Later	Zero balance on NovaCart Pay-Later.	Unpaid invoice balance.	Customer must clear balance in full.
Statutory Tax Retention	Invoices archived in cold storage for 7 years.	None (mandated by tax law).	Personal data scrubbed; tax data anonymized.

> ***Script - Deletion Confirmation:*** *'Mr./Ms. [Customer], I have initiated your account closure and Right to Erasure request. Your personal identifying data, saved addresses, and payment tokens will be permanently scrubbed within 30 days. In compliance with commercial tax law, purchase invoices will be securely anonymized and archived.'*